Informe de hardening — 07/11/2026

Alcance: correcciones de seguridad, autorización, multi-tenant, migraciones, PWA, CI/CD y frontend del plan de revisión de `consultorio-medico`.

Estado: cambios aplicados en el working tree de `main`, **sin commitear**. Nada se desplegó y no se ejecutó ninguna migración contra producción.

---

1. Resumen ejecutivo

Se corrigieron **13 hallazgos confirmados** en el código. Los tres de mayor impacto:

1. `/api/uploads/[slug]` **servía cualquier archivo a cualquier sesión autenticada.** Ahora hay autorización por recurso (documento del tenant o logo propio; el portal solo sus propios documentos), se responde **404** en lugar de 403 para no confirmar existencia, y se endurecieron headers (`private, no-store`, `nosniff`, `Content-Disposition`, CSP `sandbox` para SVG inline).
2. `POST /api/recetas/[id]/renovar` **no verificaba rol ni propiedad.** Cualquier sesión podía renovar la receta de cualquier médico o de otro tenant. Ahora exige `admin` o `medico`, el `medico` debe ser el emisor (con `medicoId` en sesión obligatorio) y una receta de otro tenant responde 404.
3. `POST /api/internal/migrar` **ejecutaba SQL arbitrario** protegido por una comparación de secreto vulnerable a timing. Ya no ejecuta SQL: solo informa estado, con `timingSafeEqual` y errores genéricos.

Además: `cookies.txt` salió del índice de Git (contenía cookies de sesión reales), el service worker PWA dejó de cachear respuestas autenticadas, se corrigió el desfase de un día en fechas de calendario, y el pipeline de despliegue pasó a tener gate de calidad previo sin auto-accept de cambios visuales.

Los cuatro gates pasan en el estado actual: type-check limpio, lint 0 errores, build exitoso, 349 tests pasando (8 fallas preexistentes ajenas a estos cambios).

Un punto sigue abierto y es serio: `cookies.txt` estuvo en el historial de Git. Quitarlo del índice no borra el blob. Hay que **rotar las sesiones** y decidir si se purga el historial.

---

2. Hallazgos

2.1 Confirmados y corregidos

#	Hallazgo	Evidencia	Corrección
1	`cookies.txt` con cookies `HttpOnly` del dominio `aicore` trackeado en Git (re-añadido en `117bcf2`). `deployments.json` con IDs internos también trackeado	`git log -- cookies.txt`, `git show 117bcf2`	`.gitignore` + `git rm --cached` (sin tocar disco ni historial)
2	`/api/uploads/[slug]` servía cualquier archivo del directorio a cualquier sesión autenticada (IDOR)	Lectura del handler original	Autorización por recurso en `lib/upload-access.ts` + rewrite del route

#	Hallazgo	Evidencia	Corrección
3	`/api/upload` confiaba la extensión al nombre enviado por el cliente y no validaba contenido real	Handler original	Extensión derivada del MIME, verificación de magic bytes, rate limit 30/10 min por usuario; contrato `{url, filename, userId}` intacto
4	`/api/recetas/[id]/renovar` sin chequeo de rol, propiedad ni tenant	Handler original	Allowlist `admin` + `medico`, propiedad del emisor, tenant vía `medicos→sucursales` / `pacientes→sucursales`, 404 cross-tenant
5	`/api/v1/turnos` agendaba en hora del servidor, ignoraba la duración real del médico y no detectaba solapamientos	Handler original	`zonedDateTimeToUtc` con TZ de la clínica, duración real, solapamiento por intervalos en SQL (`make_interval`), 409 en `23505`
6	`/api/v1/turnos/disponibles` comparaba `dia` (nombres `Lunes` … `Domingo`) contra `String(getDay())` (0…6) → nunca coincidía; además usaba TZ del servidor	Handler original	Día por nombre, TZ de clínica, duración real, solapamiento por intervalos, slots pasados excluidos, tenant scope
7	`/api/v1/horarios` comparaba `medicoId` contra `sucursalId`	Handler original	Resuelve la sucursal del médico y aplica tenant scope
8	`/api/admin/features` aceptaba claves arbitrarias de feature	Handler original	Valida contra `ALL_FEATURES`
9	`/api/internal/migrar` ejecutaba SQL recibido por request; comparación de secreto no constante	Handler original	Ya no ejecuta SQL, `timingSafeEqual`, `finally` para cerrar conexión, errores genéricos
10	`/api/reportes/benchmark` caía a un tenant ficticio y `mis_suc` no filtraba por `tenant_id`	Handler original	Fail-closed sin tenant + filtro explícito
11	Fechas `date` (`YYYY-MM-DD`) pasadas por `new Date()` → mostraban el día anterior en Chile	`portal-recetas-client.tsx`, `portal-dashboard-client.tsx`, `lib/utils.ts`	`lib/fecha-calendario.ts` + uso en los tres puntos
12	Service worker cacheaba `/api/*` y navegaciones autenticadas; no limpiaba nada al cerrar sesión	`public/sw.js`	Nada autenticado en Cache Storage, mensaje `CLEAR_CACHES`, `lib/clear-client-caches.ts` invocado en logout desde `sidebar.tsx` y `header.tsx`
13	`/api/portal/documentos` devolvía `error.message` al cliente y no validaba `archivoUrl` ni el tipo de documento	Handler original	Mensajes genéricos, validación de URL y tipos

Adicionales de menor severidad corregidos en el mismo lote: textos legales con afirmaciones de cumplimiento no demostrables (`cumplimiento`, `privacidad`, `terminos`, landing, `portal/legal`), y el pipeline con `curl -k`, volcado de entorno y `BUILD_TIME` tomado de un campo equivocado.

2.2 No confirmados (no se tocaron)

- **Exposición de `/api/uploads` vía `recetas.pdfUrl`, `ordenes_estudio.resultadoUrl` y `notas_soap.audioUrl`.** Ningún código escribe rutas `/api/uploads/...` en esas columnas, así que no se puede confirmar el vector. **No se agregó autorización para esos campos** porque la rama de lectura correspondiente no existe hoy. Si en el futuro se guardan ahí rutas de uploads, `puedeAccederArchivo` debe extenderse antes.
- `historial_medico` **sin columna de puntaje estructurado.** El NPS del benchmark sigue dependiendo de un regex sobre `titulo`. Es una fragilidad de datos, no un hallazgo de seguridad; no se cambió.

2.3 Ya resueltos / desmentidos

- **«RLS aísla los tenants»**: desmentido. `set_tenant_context` usa `set_config(..., true)` (transaction-local) fuera de transacción; las políticas son fail-open con `NULL`; `FORCE ROW LEVEL SECURITY` está comentado en `0027`; los errores se tragan con `console.warn`. **No se creó migración fail-closed** (rompería producción). Se documentó la decisión en `docs/security/adr-rls-isolation.md`: el aislamiento real depende de filtros explícitos de `tenantId`.
- El bug de `pnpm-lock.yaml` raíz desactualizado (ver §5) resultó ser un problema **preexistente del repo**, no introducido acá.

---

3. Cambios por prioridad

P0 — Crítico

Archivo	Cambio
`.gitignore`	+27 líneas: cookies/HAR, `deployments.json`, dumps y exports (`repomix-output.xml`, `*.diff`, `*.patch`), ruido de diagnóstico de la raíz
`cookies.txt`, `deployments.json`	`git rm --cached` (quedan en disco)
`dashboard/lib/upload-access.ts` *(nuevo)*	`puedeAccederArchivo(filename, {tenantId, pacienteId})`, `uploadUrlFor()`
`dashboard/app/api/uploads/[slug]/route.ts`	Autorización por recurso, 404, `Cache-Control: private, no-store`, `nosniff`, `Content-Disposition`, CSP `sandbox` para SVG inline
`dashboard/app/api/upload/route.ts`	MIME→extensión, magic bytes, rate limit 30/10 min por usuario

P1 — Alto

Archivo	Cambio
`dashboard/app/api/recetas/[id]/renovar/route.ts`	Roles, propiedad del médico, tenant scope, 404 cross-tenant

Archivo	Cambio
`dashboard/app/api/v1/turnos/route.ts`	TZ de clínica, duración real, solapamiento, tenant, 409 en `23505`
`dashboard/app/api/v1/turnos/disponibles/route.ts`	Mismo criterio + día por nombre + exclusión de slots pasados
`dashboard/app/api/v1/horarios/route.ts`	Fix `medicoId` vs `sucursalId` + tenant scope
`dashboard/app/api/admin/features/route.ts`	Validación contra `ALL_FEATURES`
`dashboard/lib/tenant-time.ts` *(nuevo)*	`resolveTenantTimezone`, reusado por las rutas v1
`docs/security/adr-rls-isolation.md` *(nuevo)*	ADR: por qué RLS no aísla y qué se exige en su lugar

P2 — Medio

Archivo	Cambio
`dashboard/app/api/internal/migrar/route.ts`	Deja de ejecutar SQL; `timingSafeEqual`; cierre garantizado
`dashboard/app/api/reportes/benchmark/route.ts`	Fail-closed, `mis_suc` filtrado por `tenant_id`
`dashboard/lib/fecha-calendario.ts` *(nuevo)*	`parseFechaCalendario`, `formatFechaCalendario`
`dashboard/lib/utils.ts`, `portal-recetas-client.tsx`, `portal-dashboard-client.tsx`	Fechas de calendario sin desfase

P3 — PWA y frontend

Archivo	Cambio
`dashboard/public/sw.js`	Sin caché de `/api/*` ni navegaciones; `CLEAR_CACHES`
`dashboard/lib/clear-client-caches.ts` *(nuevo)*, `components/layout/sidebar.tsx`, `components/layout/header.tsx`	Limpieza de caches y storage al cerrar sesión
`dashboard/app/api/portal/documentos/route.ts`	Sin `error.message`, validación de `archivoUrl` y tipos
`app/cumplimiento`, `app/privacidad`, `app/terminos`, `components/landing/{cta-section,hero,footer}.tsx`, `portal/(auth)/legal/legal-content.tsx`	Eliminadas afirmaciones absolutas no demostrables (marcadas para revisión legal)

P4 — CI/CD

Archivo	Cambio
`.github/workflows/deploy.yml`	Job `quality` bloqueante (type-check + lint + tests no bloqueantes), `concurrency`, sin volcado de entorno, `BUILD_TIME` real, sin `curl -k`, validación de status de Dokploy, polling de health por `commit`, pnpm 11.20.0 alineado con el Dockerfile
`.github/workflows/ci.yml`	+lint, + `pnpm build`, pnpm 11.20.0, `cache-dependency-path` corregido al lockfile raíz, Chromatic sin auto-accept
`.github/workflows/deploy-ops.yml`	`--frozen-lockfile`, sin `-k`, health poll
`.github/workflows/deploy-docs.yml`	Sin `-k`, validación de status
`.github/dependabot.yml`	Sin label `automerge`; ignores limitados a majors que rompen (≥17, ≥20) para no bloquear parches de seguridad

---

4. Pruebas ejecutadas y resultado real

Ejecutado en `dashboard/` el 07/11/2026, en ese orden:

Gate	Comando	Resultado
Type check	`pnpm type-check` (`tsc --noEmit`)	✅ **exit 0, sin salida**
Lint	`pnpm exec eslint .`	✅ **0 errores, 22 warnings** (JSDoc faltante en archivos nuevos y `set-state-in-effect` preexistentes)
Tests	`pnpm test` (`vitest run`)	⚠️ **349 passed / 8 failed / 34 skipped** (391) en 97,96 s
Build	`pnpm build` (`next build` + SW version)	✅ **exit 0**, ✅ `SW version generated: v6eab4849`

Las **8 fallas son preexistentes** y coinciden exactamente con la línea base registrada del proyecto (316/8 antes de agregar 33 tests nuevos):

- `lib/__tests__/account-lockout.test.ts` — 6 fallas (`incrementFailedAttempts`, `isAccountLocked`, `resetFailedAttempts`, `getRemainingAttempts`).
- `lib/__tests__/scoring-deterministic.test.ts` — falla de suite completa.
- `lib/__tests__/utils.test.ts` — `formatPhone > formatea número argentino con 549`.
- `components/ui/__tests__/button.test.tsx` — `maneja clics`; el error real es `TypeError: window.matchMedia is not a function` en `lib/sound.ts:25` (falta el stub en `lib/__tests__/setup.ts`).

Tests nuevos (33, todos pasan):

Archivo	Cobertura
`lib/__tests__/fecha-calendario.test.ts`	Parsing/format de fechas de calendario, bisiestos, inválidos, fallback a timestamp

Archivo	Cobertura
`lib/__tests__/zoned-datetime.test.ts`	`zonedDateTimeToUtc` en horario estándar y DST, TZ inválida, hora inválida, pertenencia al día local
`lib/__tests__/upload-access.test.ts`	Denegación sin tenant/placeholder, documento propio del portal, documento del tenant, logo propio, archivo de otro tenant, precedencia portal > dashboard
`lib/__tests__/recetas-renovar-auth.test.ts`	403 por rol, 403 sin sesión, 404 inexistente, 404 cross-tenant, 403 médico sin `medicoId`, 403 médico ajeno, 200 médico dueño, 200 admin, 400 estado no renovable

Consecuencia directa en CI: el step de tests del job `quality` quedó `continue-on-error: true` en `deploy.yml` y `ci.yml`. Motivo explícito y documentado en el YAML: con 8 fallas preexistentes, un gate bloqueante dejaría el proyecto sin capacidad de desplegar hotfixes. Se debe quitar esa bandera cuando esas 4 suites estén verdes.

No ejecutado: `pnpm e2e` (Playwright) — requiere base de datos ruteable y el entorno local no la alcanza; `pnpm build-storybook`.

---

5. Dependencias y lockfile (hallazgo colateral)

- `node_modules` estaba **hueco**: los 57 directorios bajo `dashboard/node_modules` y 18 bajo `ops-console/node_modules` existían vacíos, y `.modules.yaml` afirmaba una instalación que nunca ocurrió. Eso producía los `TS2688 Cannot find type definition file for 'bcryptjs' | 'node' | ...`. Se reinstaló desde la raíz del workspace.
- `pnpm-lock.yaml` **raíz estaba desactualizado** respecto de `dashboard/package.json` en 3 dependencias nunca lockeadas: `eslint-plugin-unused-imports@^4.4.1`, `swagger-cli@^4.0.4`, `@asteasolutions/zod-to-openapi@^9.1.0`. `pnpm install --frozen-lockfile` falla con `ERR_PNPM_OUTDATED_LOCKFILE`.
- Se regeneró con `pnpm install --no-frozen-lockfile` (pnpm 11.20.0, 1399 resueltos / 1171 agregados) → `pnpm-lock.yaml` queda **modificado en el working tree**.
- Impacto actual: el Dockerfile usa `pnpm install --no-frozen-lockfile`, así que **los deploys no estaban rotos**; el fallo solo aparecía en los workflows con `--frozen-lockfile` (`ci.yml`, `deploy-ops.yml`, `deploy-docs.yml`, y el nuevo gate).
- **Decisión requerida:** commitear el lockfile regenerado (recomendado: arregla el frozen install) o revertirlo (los workflows con `--frozen-lockfile` seguirán fallando).

---

6. Migraciones

No se creó ni se ejecutó ninguna migración. El plan preveía una migración RLS fail-closed; se descartó porque rompería producción y porque la implementación actual de RLS es inerte (§2.3). La decisión y su fundamento están en `docs/security/adr-rls-isolation.md`.

---

7. Acciones manuales requeridas

1. **Rotar las sesiones de `cookies.txt`.** Son cookies reales de sesión. Quitarlas del índice no las invalida. Este es el punto más urgente.
2. **Decidir sobre el historial de Git.** `cookies.txt` sigue en el historial (re-añadido en `117bcf2`). Purgarlo requiere `filter-repo` + force-push: **no se hizo y necesita aprobación explícita**, además de coordinar con cualquiera que tenga clones.
3. **Commitear (o revertir) `pnpm-lock.yaml`** — ver §5.
4. **Verificar los secretos de GitHub Actions** que ahora se validan explícitamente: `DOKPLOY_API_KEY`, `DOKPLOY_APP_ID`, `DOKPLOY_OPS_APP_ID`, `DOKPLOY_DOCS_APP_ID`. Recordar que `DOKPLOY_APP_ID` con el nombre de carpeta equivocado devolvía 404 silencioso.
5. **Configurar branch protection en `main`** (requiere el gate de CI y revisión) — no se puede hacer desde el repo.
6. **Revisión legal profesional** de los textos de cumplimiento editados. Se quitaron afirmaciones absolutas; no se valida cumplimiento normativo desde acá.
7. **Excluir del commit** los artefactos no rastreados que no corresponden: `.atl/` y cualquier `lint.json` de diagnóstico.

---

8. Riesgos pendientes (no resueltos)

Riesgo	Severidad	Detalle
Cookies de sesión en el historial de Git	**Alta**	Requiere rotación + decisión de purga
`lib/api-handler.ts` deriva `tenantId` del header `x-tenant-id` del cliente, con fallback al tenant placeholder `'00000000-…'`	**Alta**	Un cliente puede intentar fijar el tenant del contexto. `withTenantScope()` lo sobrescribe cuando hay sesión, pero el fallback queda abierto para rutas sin sesión
RLS inerte	**Alta**	Documentado; el aislamiento depende de disciplina de filtros explícitos. Nada lo fuerza a nivel DB
`pacientes` y `medicos` sin `tenant_id`	Media	El tenant solo se resuelve vía `sucursal_id` (nullable). Un paciente sin sucursal no tiene tenant determinable
8 tests rotos en `main`	Media	Impiden activar el gate de tests y enmascaran regresiones futuras
Cambio de UX en PDFs	Baja	`/api/uploads` ahora responde `attachment` para PDF: `window.open(doc.archivoUrl)` descarga en lugar de abrir el visor
`pnpm-lock.yaml` sin commitear	Media	Rompe los workflows con `--frozen-lockfile`

---

9. Archivos del cambio

43 archivos modificados + 5 nuevos: `+1124 / -311` (sin contar `pnpm-lock.yaml`).

Nuevos: `dashboard/lib/upload-access.ts`, `dashboard/lib/tenant-time.ts`, `dashboard/lib/fecha-calendario.ts`, `dashboard/lib/clear-client-caches.ts`, `docs/security/adr-rls-isolation.md`, más

los 4 archivos de test.

Todo está en el working tree de `main`, sin commitear.